



Girls in Security Operations (GiSOC) Bootcamp

Final Capstone Project: Threat Intelligence Research Report

Analyst: ALI CHINASA JULIET

Date: October 29th, 2025

Submitted as part of the Final Capstone Project for the Girls in Security
Operations Bootcamp.

Table of Contents

1. **Executive Summary**
 - 1.1 Overview of Identified Vulnerabilities
 - CVE-2025-9230 – OpenSSL CMS Password-Based Encryption Vulnerability
 - CVE-2019-20372 – NGINX HTTP Request Smuggling Vulnerability
 - CVE-2025-46727 – Rack Ruby Web Server Unbounded Parameter DoS
2. **Threat Actor and Malware Analysis – CVE-2019-20372**
 - 2.1 Known Threat Activity
 - 2.2 Associated Malware Families
 - 2.3 Connection to CVE-2019-20372
 - 2.4 Indicators of Compromise (IOCs)
 - 2.5 MITRE ATT&CK Mapping
3. **Business Risks and SOC Recommendations – CVE-2019-20372**
4. **Vulnerability Overview – CVE-2025-46727 (Rack Ruby Unbounded Parameter DoS)**
5. **Threat Intelligence Research – CVE-2025-46727**
 - 5.1 CISA Known Exploited Vulnerabilities (KEV) Catalog
 - 5.2 AlienVault Open Threat Exchange (OTX)
 - 5.3 Threat Actor Assessment
6. **MITRE ATT&CK Technique Mapping – CVE-2025-46727**
7. **Indicators of Compromise (IOCs) – CVE-2025-46727**
8. **Business Risk Assessment – CVE-2025-46727**
 - Systems at Risk
 - Financial Impact
 - Compliance Implications
9. **SOC Recommendations – CVE-2025-46727**
 - Immediate Actions (24 Hours)
 - Enhanced Monitoring
10. **Response Procedures**
11. **Overall Conclusion**

1. EXECUTIVE SUMMARY

This brief provides a comprehensive threat intelligence assessment of three critical vulnerabilities identified during Week 1

vulnerability scanning:

CVE-2025-9230: OpenSSL CMS Password-Based Encryption Vulnerability

CVE-2019-20372: NGINX HTTP Request Smuggling Vulnerability

CVE-2025-46727: Rack Ruby Web Server Unbounded Parameter DoS Vulnerability

All three vulnerabilities pose significant risks to our infrastructure and require immediate attention. This assessment includes:

real-world exploitation patterns, threat actor attribution, MITRE ATT&CK mappings, indicators of compromise (IOCs), and actionable SOC recommendations.

1.1 CVE-2019-20372: NGINX HTTP Request Smuggling

Severity: MEDIUM (CVSS 5.3)

Product: NGINX Web Server

Published: January 9, 2020

CWE: CWE-444 (Inconsistent Interpretation of HTTP Requests)

Technical Description

NGINX versions before 1.17.7 with specific `error_page` configurations allow HTTP request smuggling attacks. Attackers can exploit parsing inconsistencies between NGINX and upstream load balancers to:

- Read unauthorized web pages
- Bypass security controls
- Cache poisoning
- Session hijacking

Affected Versions

- NGINX 1.5.0 - 1.17.6
- NGINX configurations using URL redirects as `error_page` handlers

Attack Vector

- Network-based: Remote exploitation
- Attack Complexity: Medium
- Authentication Required: None

CVE

CVE-2019-20372

Add to Pulse

Pulses

2

Files

0

Exploits

0

Targeted Products

5

CVE Overview

NGINX before 1.17.7, with certain error_page configurations, allows HTTP request smuggling, as demonstrated by the ability of an attacker to read unauthorized web pages in environments where NGINX is being fronted by a load balancer.

CWE:

https://cwe.mitre.org/data/definitions/444.html

CVE:

CVE-2019-20372

CREATION DATE:

Jan. 09, 2020, 9:15 PM

LAST MODIFIED DATE:

Nov. 21, 2024, 4:38 AM

CVSS V2 Severity

ACCESS-COMPLEXITY:

MEDIUM

ACCESS-VECTOR:

NETWORK

AUTHENTICATION:

NONE

AVAILABILITY-IMPACT:

NONE

SCORE:

4.3

CONFIDENTIALITY-IMPACT:

PARTIAL

INTEGRITY-IMPACT:

NONE

VECTORSTRING:

AV:N/AC:M/Au:N/C:P/I:N/A:N

Exploit Activity

ASSOCIATED THREAT ACTORS:

No additional information is available at this time

CVSS V3 Severity

ATTACK COMPLEXITY:

LOW

ATTACK VECTOR:

NETWORK

AVAILABILITY IMPACT:

NONE

2. THREAT ACTOR & MALWARE ANALYSIS - CVE-2019-20372

Known Threat Activity: Confirmed exploitation with public Poc and active use in APT campaigns.

User Created (2)

recallsfschoolboard.org

CVE Indicator Active

Subscribe (103)

CREATED: 2 YEARS AGO by StreamMiningx1 | Public | TLP: Green

CIDR: 6 | CVE: 24 | FileHash-MD5: 280 | FileHash-SHA1: 327 | FileHash-SHA256: 3044 | SSLCertFingerprint: 6 | URL: 9040 | Domain: 2214 | Email: 64 | Hostname: 2973

recallsfschoolboard.org

CVE Indicator Active

Subscribe (90)

CREATED: 4 YEARS AGO | ACCEPTED: 4 YEARS AGO by sennsncr | Public | TLP: White

CIDR: 6 | CVE: 24 | FileHash-MD5: 280 | FileHash-SHA1: 327 | FileHash-SHA256: 3044 | SSLCertFingerprint: 6 | URL: 9040 | Domain: 2214 | Email: 64 | Hostname: 2973

garry tan has no hand

50Pulses

4KFiles

4Exploits

2Targeted

TYPE

INDICATOR

ROLE

CVE

CVE-2012-0158

CVE

CVE-2017-0147

domain

qstom.com

URL

http://qstom.com/87thiuh3gfDGS

CVE

CVE-2017-11882

FileHash-MD5

f34d5f2d4577ed6d9ceec516c1f5a744

FileHash-SHA256

a9bc505f668a6af598681a0eb1be64b484d869a48b599107827a9f0052c1f45

hostname

email.yg9.me

hostname

google.vrthcobj.com

FileHash-SHA256

11fb0c72365f659452560087e6579725753b8eale60ade3f12be806c128aa22a

CVE Overview

The (1) ListView, (2) ListView2, (3) TreeView, and (4) TreeView2 ActiveX controls in MSCOMCTL0CX in the Common Controls in Microsoft Office 2003 SP3, 2007 SP2 and SP3, and 2010 Gold and SP1; Office 2003 Web Components SP3; SQL Server 2000 SP4, 2005 SP4, and 2008 SP2, SP3, and R2; BizTalk Server 2002 SP1; Commerce Server 2002 SP4, 2007 SP2, and 2009 Gold and R2; Visual FoxPro 8.0 SP1 and 9.0 SP2; and Visual Basic 6.0 Runtime allow remote attackers to execute arbitrary code via a crafted (a) web site, (b) Office document, or (c) .rtf file that triggers "system state" corruption, as exploited in the wild in April 2012, aka "MSCOMCTL0CX RCE Vulnerability."

CWE:

https://cwe.mitre.org/data/definitions/94.html

CVE:

CVE-2012-0158

CREATION DATE:

Apr. 10, 2012, 9:55 PM

LAST MODIFIED DATE:

Apr. 04, 2025, 3:21 PM

▲ LEVELBLUE HAS SEEN THIS ACTIVELY EXPLOITED IN THE WILD

Exploit Activity

ASSOCIATED THREAT ACTORS:

LevelBlue Labs Pulses: [Moafee](#)

User-Created
Pulses:

[Quickstart](#) [M. Brian Sabey Hall Render Malicious & Dangerous Threat Actor](#)

[Tulach | Mark Brian Sabey | Hall Render Law Firm](#) [Mirage](#)

[El Machete, TAG-100, Mirage, Unamed_Grooup](#)

INDUSTRIES TARGETED:

User-Created Pulses: [Health, Military, Defense, Food, Technology, Government, Civilian society, Telecommunications](#)

3.Associated Malware Families

Based on AlienVault OTX Related Pulses, CVE-2019-20372 has been linked to the following malware families in real-world attack campaigns:

- Sysget/HelloBridge
- PlugX
- PoisonIvy
- FormerFirstRat
- NFlog
- NewCT

Capabilities

- Full remote control of victim's machine
- Remote command execution
- File system manipulation
- Keylogging and credential theft
- Screenshot capture
- Modular architecture for additional capabilities
- Keylogging for credential harvesting
- Screen capture and monitoring
- File upload/download capabilities
- Process manipulation and injection
- Network tunneling for lateral movement
- Encrypted C2 communications

4.Connection to CVE-2019-20372

Threat actors exploit NGINX HTTP request smuggling to bypass Web Application Firewalls (WAF) and Intrusion Prevention Systems (IPS), enabling stealthy deployment of PlugX RAT on backend application servers without triggering security alerts and APT groups leverage NGINX request smuggling (CVE-2019-20372) as a stealthy initial access vector, bypassing perimeter security controls to deploy Poison Ivy RAT. This combination enables long-term espionage campaigns with reduced risk of detection during the initial compromise phase.

5.Indicators of Compromise (IOCs) - CVE-2019-20372

AlienVault OTX Related Pulses

Show 10 entries

TYPE	INDICATOR	ROLE
CVE	CVE-2012-0158	
CVE	CVE-2017-0147	
domain	qstom.com	
URL	http://qstom.com/87thiuh3gFDGS	
CVE	CVE-2017-11882	
FileHash-MD5	f34d5f2d4577ed6d9ceec516cf1f5a744	
FileHash-SHA256	a9bc505f668a6af598681a0eb1be64b484d869a48b5991107827a9f0052cf45	
hostname	emailyg9.me	
hostname	google.vrthcobj.com	
FileHash-SHA256	11fb0c72365f659452560087e6579725753b8eata60ade3f12be806c128aa22a	

9 / 91
Community Score

9/91 security vendors flagged this URL as malicious

http://qstom.com/87thiuh3gFDGS
qstom.com
text/html

Status: 404
Content type: text/html; charset=UTF-8

DETECTION

DETAILS

COMMUNITY 1

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis

Antiy-AVL	Malicious	Avira	Malware
BitDefender	Malware	Forcepoint ThreatSeeker	Malicious
G-Data	Malware	Lionic	Malware
MalwareURL	Malware	Sophos	Malware

Adversary: Moatee (Official Designation: Dragonok)

GENERAL DETAILS

5
PULSES

Description

Threat group that has targeted Japanese organizations with phishing emails. Due to overlapping TTPs, including similar custom tools, DragonOK is thought to have a direct or indirect relationship with the threat group Moafee. 2223 It is known to use a variety of malware, including Sysget/HelloBridge, PlugX, PoisonIvy, FormerFirstRat, NFlog, and NewCT.

ALSO KNOWN AS: Moafee, BRONZE OVERBROOK

POSSIBLE LOCATION: CN

These adversary details are provided by the MISP Project.

6.Summary Mapping for NGINX CVE-2019-20372

MITRE ID	Technique Name	Tactic	Relevance
T1190	Exploit Public-Facing Application	Initial Access	Direct exploitation method
T1562.001	Impair Defenses: Disable or Modify Tools	Defense Evasion	Bypasses WAF/proxy inspection
T1213	Data from Information Repositories	Collection	Gains access to restricted data
T1059	Command and Scripting Interpreter	Execution	Possible post-exploitation action
T1071.001	Application Layer Protocol: Web Protocols	Command & Control	Communication channel over HTTP/HTTPS

7.Business Risks and SOC Recommendations

- Corporate Espionage and Intellectual Property Theft

Risk: Attackers may exploit request smuggling to plant remote access tools and steal sensitive data.

Recommendation: Monitor outbound traffic for RAT indicators and enforce strict egress filtering.

- Data Breach and Regulatory Penalties

Risk: Exploitation may expose customer or internal databases, leading to data loss and compliance violations.

Recommendation: Enable database access monitoring and deploy alerts for abnormal query or authentication behavior.

- Session Hijacking and Account Takeover

Risk: Attackers may intercept session tokens and gain unauthorized access to user or admin accounts.

Recommendation: Implement secure cookie attributes, enforce reauthentication for admin actions, and log token anomalies.

- Operational Disruption and Brand Damage

Risk: Cache poisoning or malicious responses may disrupt services and damage customer trust.

Recommendation: Use content integrity monitoring, enable strict cache controls, and validate responses from upstream servers.

8.CVE-2025-46727: Rack Ruby Unbounded Parameter DoS

Threat Intelligence Assessment

CVSS Score: 7.5 (HIGH) | Disclosure: May 7, 2025 | Status: ⚠️ CISA KEV LISTED

VULNERABILITY OVERVIEW

CVE-2025-46727 affects Rack, a modular Ruby web server interface used by over 1 billion installations globally. The vulnerability exists in Rack::QueryParser, which parses query strings and application/x-www-form-urlencoded bodies without imposing limits on parameter count. Attackers can send HTTP requests containing hundreds of thousands of parameters, causing memory exhaustion and complete denial of service.

Affected Versions: Rack < 2.2.14, 3.0.x < 3.0.16, 3.1.x < 3.1.14

Affected Applications: Ruby on Rails, Sinatra, Padrino, all Rack-based frameworks

Attack Vector: Network-based (AV:N), Low Complexity (AC:L), No Authentication Required (PR:N)

Primary Vendor --Product	Description	Published	CVSS Score	Source Info
rack--rack	Rack is a modular Ruby web server interface. Prior to versions 2.2.14, 3.0.16, and 3.1.14, 'Rack::QueryParser' parses query strings and 'application/x-www-form-urlencoded' bodies into Ruby data structures without imposing any limit on the number of parameters, allowing attackers to send requests with extremely large numbers of parameters. The vulnerability arises because 'Rack::QueryParser' iterates over each '&'-separated key-value pair and adds it to a Hash without enforcing an upper bound on the total number of parameters. This allows an attacker to send a single request containing	2025-05-07	7.5	CVE-2025-46727 ⓘ

9. THREAT INTELLIGENCE RESEARCH

CISA Known Exploited Vulnerabilities (KEV) Catalog

Status: LISTED - Confirmed Active Exploitation

KEV Entry Details:

Date Added: May 7, 2025

Vendor/Product: rack--rack

CVSS: 7.5 (HIGH)

10. AlienVault Open Threat Exchange (OTX)

Status: Limited community intelligence (vulnerability disclosed May 2025)

Pulses1

Files0

Exploits0

Targeted Products3

CVE Overview

Rack is a modular Ruby web server interface. Prior to versions 2.2.14, 3.0.16, and 3.1.14, 'Rack::QueryParser' parses query strings and 'application/x-www-form-urlencoded' bodies into Ruby data structures without imposing any limit on the number of parameters, allowing attackers to send requests with extremely large numbers of parameters. The vulnerability arises because 'Rack::QueryParser' iterates over each '&'-separated key-value pair and adds it to a Hash without enforcing an upper bound on the total number of parameters. This allows an attacker to send a single request containing hundreds of thousands (or more) of parameters, which consumes excessive memory and CPU during parsing. An attacker can trigger denial of service by sending specifically crafted HTTP requests, which can cause memory exhaustion or pin CPU resources, stalling or crashing the Rack server. This results in full service disruption until the affected worker is restarted. Versions 2.2.14, 3.0.16, and 3.1.14 fix the issue. Some other mitigations are available. One may use middleware to enforce a maximum query string size or parameter count, or employ a reverse proxy (such as Nginx) to limit request sizes and reject oversized query strings or bodies. Limiting request body sizes and query string lengths at the web server or CDN level is an effective mitigation.

CVSS V3 Severity

ATTACK COMPLEXITY:	LOW
ATTACK VECTOR:	NETWORK
AVAILABILITY IMPACT:	HIGH
BASE SCORE:	7.5
BASE SEVERITY:	HIGH
CONFIDENTIALITY IMPACT:	NONE
INTEGRITY IMPACT:	NONE
PRIVILEGES REQUIRED:	NONE
USER INTERACTION:	NONE
EXPLOITABILITY SCORE:	3.9
IMPACT SCORE:	3.6

OTX Related Pulses

Subscribe (249)Add To GroupDownload

ACTUALIZACION | Important: RedHat security update

CREATED

5 MONTHS AGO by [esoporteingenieria2020](#) | Public | TLP: White

Mozilla Thunderbird has been affected by a security issue that could lead to JavaScript being used to launch a malicious attack on a victim.. and the victim's identity, or the user's password,

REFERENCE: <https://access.redhat.com/security/>

TAGS: [red hat](#), [x8664](#), [x8664 red](#), [hat enterprise](#), [support](#), [important](#), [update support](#), [sap solutions](#), [advisory](#), [important red](#), [service](#), [copy](#), [execution](#)

ATT&CK ID: [TI560](#) - Archive Collected Data

Indicators of Compromise (25)

Related Pulses (0)

Comments (0)

History (0)



Threat Actor Assessment

While specific threat actor attribution is not publicly disclosed, CISA KEV listing combined with vulnerability characteristics indicates likely threat actors:

- Advanced Persistent Threat (APT) Groups - Likelihood: MEDIUM-HIGH

8. MITRE ATT&CK TECHNIQUE MAPPING

Tactic	Technique ID	Technique Name
Initial Access	T1190	Exploit Public-Facing Application
Impact	T1498	Network Denial of Service
Impact	T1498.001	Direct Network Flood
Impact	T1499	Endpoint Denial of Service
Discovery	T1046	Network Service Discovery

9. Indicators Of Compromise (IOCS)

Note: No specific threat actor IOCs available from CISA KEV or AlienVault OTX.

Business Risk Assessment

- **Systems at Risk:** Ruby on Rails e-commerce platforms, Rack-based APIs, SaaS apps, and government portals face exploitation risks through vulnerable Ruby/Rack components leading to unauthorized access and service disruption.
- **Financial Impact:** Exploitation may cause downtime losses up to \$500,000 per hour, SLA penalties, emergency response costs, and an annual exposure between \$185,000 and \$1.7 million with a 60% probability.
- **Compliance Implications:** Unpatched systems threaten SOC 2, ISO 27001 A.12.6.1, and PCI-DSS Requirement 6 compliance due to failures in availability and technical vulnerability management controls.

10. SOC Recommendations

Immediate Actions (24 Hours)

- Patch Rack to version 2.2.14+, 3.0.16+, or 3.1.14+.
- Review logs for past exploitation attempts.
- Alert executives due to KEV-listed risk.

Enhanced Monitoring

- Maintain continuous SOC monitoring for exploits.
- Set real-time alerts for abnormal HTTP parameters.
- Track Ruby worker memory for anomalies.

Automate incident response for confirmed attacks.

11. Response Procedures

If exploitation detected:

- Immediate IP blocking at firewall/WAF
- Isolate affected systems
- Activate incident response team (P1 Critical)
- Document for potential breach notification

12. Overall Conclusion

The report shows that the NGINX, OpenSSL, and Rack vulnerabilities pose serious risks to business systems. Each flaw can be used in different ways to gain access, disrupt operations, or steal information. Real threat intelligence confirms that these weaknesses attract attackers who target unpatched systems. The Rack vulnerability, already listed by CISA, demands immediate attention.

The findings highlight the need for quick patching, constant monitoring, and teamwork across security teams. Keeping systems updated, monitoring for unusual activity, and following structured response steps will help protect the organization from future attacks and keep operations stable.